ARCHITECTURE AND DECISION RECORD

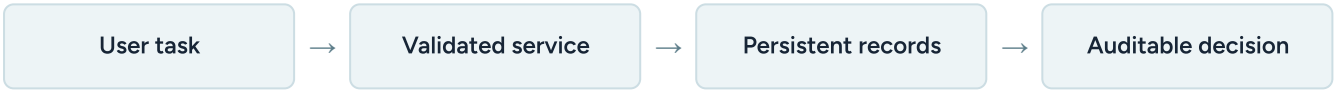
A consent-based security awareness training platform

Daniel Villanueva · Application security and network assurance reviewer

Threat modeling | Authorization | Security testing | PostgreSQL

Problem and contribution

This original design case study explores how to teach and assess recognition of suspicious-message cues in a transparent, controlled environment without harvesting real credentials. I authored the requirements breakdown, architecture boundaries, data relationships, failure scenarios, and review rationale presented here. The design is a fictional presentation example, with no claim of a production deployment or measured client result.



Architecture decisions and tradeoffs

- Use reserved example addresses and local simulated destinations; no payload should reach an outside inbox or credential collection endpoint.
- Store the scenario version and rubric used for each response so later content changes do not silently change historical scores.
- Provide feedback privately and avoid leaderboard designs that stigmatize learners.

Core records

Record	Responsibility
training_modules	Each module has reviewed synthetic scenarios aligned to one objective.
scenarios	Scenarios have versions so a past assessment retains the question actually seen.
assessment_sessions	A session stores consent context and a bounded assessment attempt.
responses	Responses preserve choices; they never store real third-party credentials.

The service layer owns authorization and business constraints. Interface validation improves the experience but cannot replace server checks. Event records preserve attributable decisions and their timing without logging unnecessary private content.

VERIFICATION AND REVIEW PRACTICE

Failure cases, evidence, and limitations

Proposed verification matrix

Scenario	Method	Expected behavior
Safe simulation	Inspect every scenario URL, attachment label, and destination in the training environment.	All interactive examples remain local or non-routable and request no real password.
Scoring reproducibility	Recalculate results from stored responses and the original rubric version.	The reconstructed result matches the issued feedback exactly.
Permission boundary	Attempt to view another learner's response detail and a small-cohort report.	Personal results remain private and suppressed aggregates are not disclosed.
Learning evaluation	Compare distinct pre/post item sets and a later retention check with consent.	Report uncertainty, item difficulty, and attrition rather than a universal security improvement.

Technical review

Use synthetic destinations and never collect real passwords. Keep individual feedback private, store the rubric version, and distinguish improved quiz recognition from evidence of reduced real-world compromise.

How to evaluate the design

Measure rubric-based recognition, false positives, explanation quality, and retention using different but comparable item sets. Record confidence separately from correctness. Changes in quiz scores do not prove reduced real-world compromise, and no such claim is made.

The matrix specifies intended tests, not completed test results. A reviewer should capture the environment, initial records, inputs, expected state, observed state, and any unresolved defect before interpreting the outcome. Repeated runs should use separate unique request keys where relevant and preserve failures for analysis.

Scope limitations

No live phishing campaigns, credential harvesting, malware, external message sending, employee surveillance, or guarantee of resistance to real attacks.

Review whether the study measures understanding rather than memorized cues and whether every simulated interaction remains safe and consent-based.

> **Authorship and reuse**
>
> Prepared by Daniel Villanueva as an original presentation work sample. All narrative, schemas, and test scenarios are original illustrative material. There are no external client documents, employment certificates, real personal records, or fabricated citations in this case study.